Design Pattern Role-Based Access Control

Intento e contesto

Il design pattern RBAC ha l'intento di gestire la sicurezza permettendo agli utenti di acquisire diritti di accesso in base alle funzioni o ai compiti che svolgono nel loro lavoro (i ruoli), piuttosto che assegnare diritti direttamente alle singole persone.

È particolarmente indicato in contesti con un gran numero di utenti, molte tipologie di informazioni e una grande varietà di risorse da proteggere.

Il **problema** è che se si assegnassero i diritti di accesso direttamente ai singoli utenti, l'amministrazione diventerebbe estremamente complessa e difficile da tracciare. Bisogna quindi bilanciare diverse forze:

1. classificare le persone in base ai loro compiti.
2. raggruppare i diritti necessari per compiti comuni.
3. applicare il principio del "**need-to-know**" (dare il minimo delle informazioni necessarie ai diretti interessati).

La **soluzione** proposta è quella di disaccoppiare gli utenti dai permessi introducendo il concetto di **ruolo.**

- le organizzazioni hanno vari ruoli che richiedono diverse responsabilità.
- i ruoli sono associati ai permessi.
- gli utenti sono assegnati ai ruoli.

In questo modo, un utente acquisisce i permessi solo attraverso i ruoli che gli sono stati assegnati.

Struttura e partecipanti

1. **User**: rappresenta l'utente (o account) registrato. Non contiene direttamente permessi operativi, ma contiene solo credenziali e riferimento ai ruoli assegnati.
2. **Role**: è il cuore del modello che descrive una funzione lavorativa o un insieme di compiti predefiniti (coerente di responsabilità). Il ruolo aggrega i permessi e riflette la struttura organizzativa reale.
3. **Permission**: definisce il tipo di accesso consentito (ad esempio, lettura o scrittura) su una risorsa. Formalmente è quindi l'autorizzazione ad eseguire una certa operazione su un certo ProtectionObject.
4. **ProtectionObject**: è l'oggetto o la risorsa da proteggere. È lo stesso concetto visto nel Reference Monitor.
5. **Session**: mappa un utente a un insieme di ruoli attivi. Durante una sessione, l'utente può attivare o disattivare specifici ruoli che gli sono stati assegnati. È importante perché un utente può avere più ruoli assegnati, ma non è detto che li usi tutti contemporaneamente. Questo permette la separazione dei compiti e principio del minimo privilegio dinamico. Ad esempio, Alice è sia Participant che Auditor, ma durante una sessione può attivare solo Participant.

Funzionamento e dinamiche

1. **Configurazione** (inizializzazione): si crea l'utente, si creano i ruoli e i permessi, e si salvano le associazioni (es. tramite un metodo saveUser e saveSession). Questo spesso coinvolge un componente **Registry** o un database.
2. **Verifica dell'accesso** (runtime): quando un utente richiede un'operazione, il sistema verifica se possiede l'autorizzazione necessaria attraverso i seguenti passaggi:
   a. si recupera la Session dell'utente.
   b. si recuperano i ruoli attivi (getActiveRoles).
   c. si chiede al ruolo se possiede il permesso richiesto (hasPermission(p)).
   d. se il permesso corrisponde (equals(p)), l'accesso è garantito.

Diagramma UML di sequenza

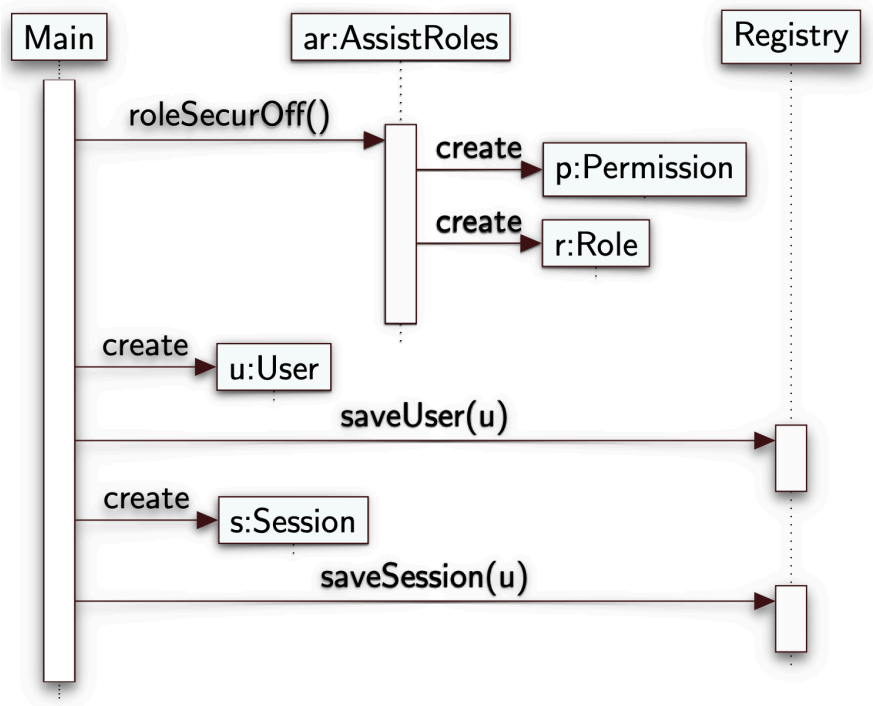
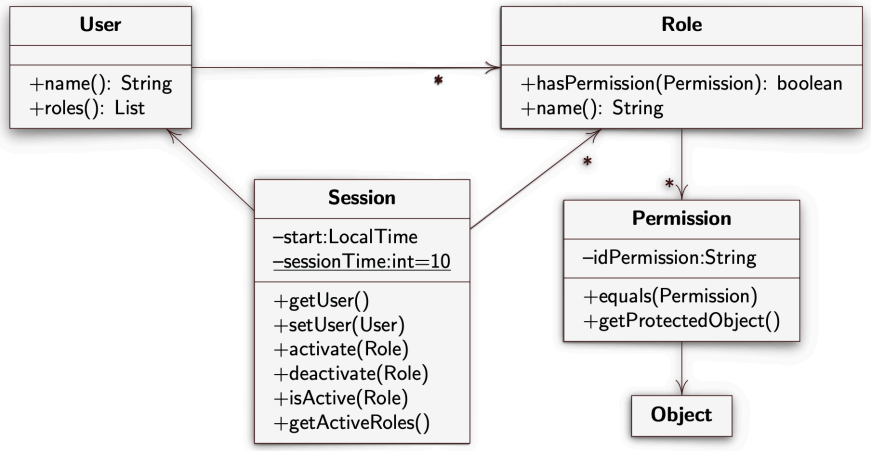


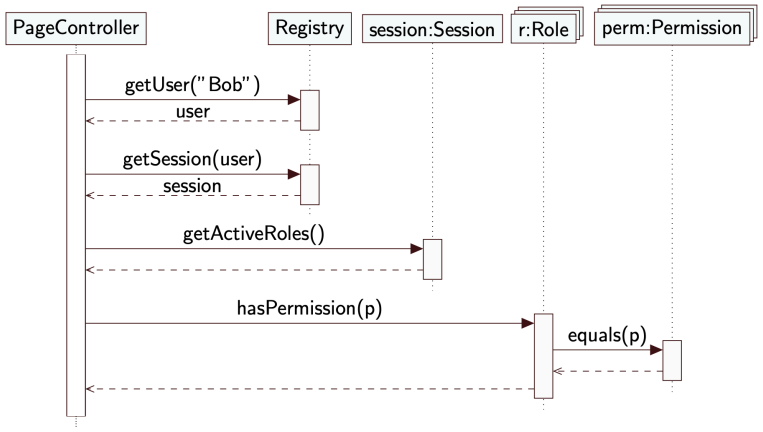
Diagramma UML delle classi

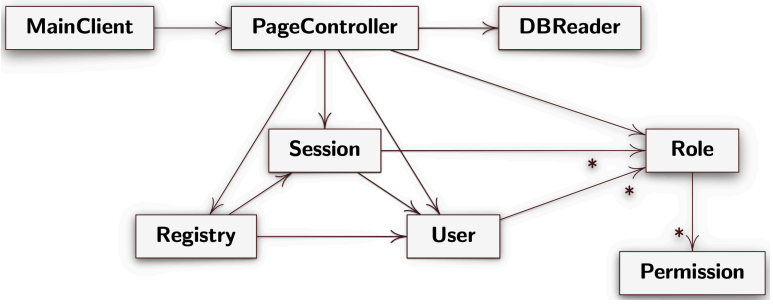


Esempio applicativo

Nel caso della gestione di missioni umanitarie:

- **Ruoli**: SecurityOfficer, Participant, Secretary.
- **Utenti**: Bob (SecurityOfficer), Alice (Participant).
- **Oggetti**: Refugee, Device, Alert, Disk.
- **Permessi**:
  - Il Participant può leggere o aggiornare i dati dei rifugiati (readRefugee, updateRefugee).
  - Il SecurityOfficer può inviare allarmi (sendAlert).
- L'appartenenza generica all'organizzazione non basta. L'accesso alle risorse (oggetti, come Refugee o Alert) è dettato esclusivamente dal ruolo attivo.





Collegamento con Reference Monitor

Mentre RBAC (*policy model*) definisce la politica di autorizzazione, il Reference Monitor (*policy enforcement mechanism*) la applica.

Quindi il monitor, quando riceve una Request, può verificare se la sessione dell'utente ha un ruolo con il permesso richiesto.

Conseguenze e vantaggi

L'adozione di RBAC porta diversi benefici amministrativi:

- **Riduzione della complessità**: poiché solitamente ci sono molti più utenti che ruoli, gestire i permessi sui ruoli è molto più semplice che gestirli per ogni singolo utente.
- **Mapping diretto**: le politiche aziendali sulle mansioni lavorative si traducono facilmente direttamente nella definizione dei ruoli software.
- **Gestione del turnover**: quando un utente cambia lavoro o lascia l'organizzazione, basta modificare l'associazione utente-ruolo senza dover toccare la configurazione dei permessi sulle risorse.